Peer Response 2

Your analysis of the limitations of CVSS as a primary means of prioritising vulnerabilities seems to be justified. Especially, your argument about the distinction between technical severity and organisational risk deserves to be highlighted. Wunder et al. (2024) explain that CVSS metrics can be interpreted differently by different users; therefore, the prioritisation of vulnerabilities would differ accordingly.

One possible solution to this problem could be regular revision of the prioritisation of vulnerabilities based on the context and threat situation. For instance, security departments could take into account the significance of the system, its exploitation, and the implications for the organisation. Thus, security departments could avoid making a decision based only on the numerical value of CVSS without considering other aspects.

I also find your views on EPSS to be very insightful. The combination of exploitation probability and technical impact may help in creating a more comprehensive way of assessing vulnerabilities. It will assist in the effective utilisation of available resources by decreasing the risk posed by threats with more urgent potential.

References

- Aven, T. and Thekdi, S. (2025) Risk Science. 3rd edn. Abingdon: Routledge.
- Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) ‘Shedding Light on CVSS Scoring Inconsistencies: A User-Centric Study on Evaluating Widespread Security Vulnerabilities’, 2024 IEEE Symposium on Security and Privacy (SP), pp. 1102–1121.